

MARCO INTEGRATIVO GQM + PRAGMATIC

Trazabilidad Completa: Objetivos Nacionales → Preguntas → Métricas Calificadas

CIA Triad Metrics Framework — España 2025

"Medir sin objetivo es coleccionar números. Medir con objetivos pero sin calidad es engañarse con estadísticas. GQM aporta la brújula; PRAGMATIC, el calibrador. Juntos, son el método científico aplicado a la resiliencia digital de una nación."

SECCIÓN 1: FUNDAMENTOS DEL MARCO INTEGRATIVO

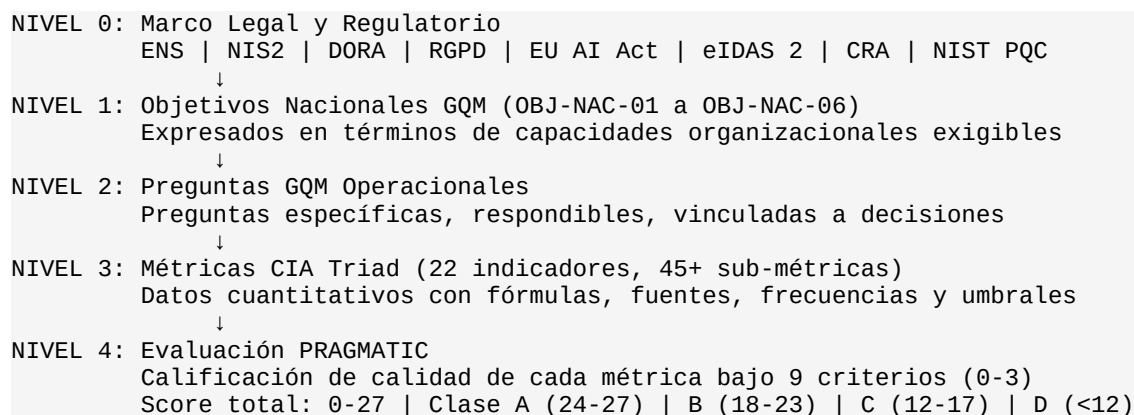
1.1 Génesis y Justificación

El presente Marco Integrativo GQM+PRAGMATIC para el CIA Triad surge de una necesidad no resuelta en la literatura española de ciberseguridad: la ausencia de un sistema de métricas que satisfaga simultáneamente cuatro condiciones que, por separado, ya son difíciles de alcanzar:

1. Trazabilidad normativa: Cada métrica debe poder rastrearse hasta un objetivo de política nacional y un artículo regulatorio específico.
2. Calidad metodológica evaluada: No basta con que la métrica exista; debe evaluarse su adecuación mediante criterios explícitos y reproducibles.
3. Aplicabilidad práctica: Las métricas deben ser implementables con los recursos reales de las organizaciones españolas, no solo con los de las 35 del IBEX.
4. Cobertura del CIA Triad completo: Confidencialidad, Integridad y Disponibilidad, más sus extensiones hacia Autenticidad y Trazabilidad (CIANA), tratadas con la misma profundidad.

El marco GQM (Goal-Question-Metric) fue propuesto por Victor Basili y David Weiss en 1984 para el NASA Software Engineering Laboratory y codificado posteriormente en ISO/IEC 15939. El marco PRAGMATIC fue formalizado por Brotby y Hinson en su obra "A Practical Introduction to Information Security Measurement" (2013) como extensión de las guías NIST SP 800-55. La integración de ambos en un único marco aplicado al contexto normativo español de 2025 es la contribución original de este documento.

1.2 Estructura del Marco: Cuatro Niveles de Análisis



SECCIÓN 2: LOS SEIS OBJETIVOS NACIONALES GQM

OBJ-NAC-01: Protección de Confidencialidad de Datos

Declaración completa: Garantizar que los datos personales, estratégicos y operacionales de ciudadanos, empresas e instituciones españolas estén protegidos contra acceso, exfiltración o divulgación no autorizados.

Base normativa: RGPD Art. 5(1)(f) y Art. 32; ENS RD 311/2022 Dimensión Confidencialidad; NIS2 Art. 21(2)(i); EU AI Act Art. 9.

Indicadores asignados: C-01 (MFA), C-02 (IAM), C-03 (Cifrado), C-05 (DLP), C-06 (Shadow AI)

Pregunta GQM de nivel superior: ¿En qué medida pueden las organizaciones españolas garantizar que solo los usuarios autorizados acceden a los datos que les corresponden?

OBJ-NAC-02: Integridad y Autenticidad de Sistemas e Información

Declaración completa: Garantizar que los datos, sistemas y componentes software en el ecosistema digital español permanezcan completos, exactos y no adulterados, desde su creación hasta su eliminación.

Base normativa: ENS Dimensión Integridad; NIS2 Art. 21(2)(b) y (d); EU CRA Arts. 13-15.

Indicadores asignados: I-01 (FIM), I-02 (TMPVC), I-03 (Supply Chain), I-04 (Firma Digital), I-05 (Logs)

Pregunta GQM de nivel superior: ¿En qué medida pueden las organizaciones españolas garantizar que sus datos y sistemas no han sido alterados sin autorización documentada?

OBJ-NAC-03: Disponibilidad y Resiliencia de Servicios Críticos

Declaración completa: Garantizar que los servicios digitales esenciales para ciudadanos, empresas e infraestructuras críticas españolas permanezcan disponibles, recuperables y resilientes frente a interrupciones intencionadas o accidentales.

Base normativa: DORA Arts. 8, 11, 12, 17; NIS2 Art. 21(2)(a)(c)(e); ENS Dimensión Disponibilidad; ISO 22301:2019.

Indicadores asignados: A-01 (MTTD), A-02 (MTTR/MTTC), A-03 (RTO/RPO), A-04 (Uptime), A-05 (Ransomware), A-06 (Edge Devices)

Pregunta QQM de nivel superior: ¿En qué medida pueden las organizaciones españolas garantizar la continuidad y recuperación de sus servicios críticos dentro de los umbrales de tiempo definidos?

OBJ-NAC-04: Autenticidad e Irrefutabilidad de Identidades y Transacciones

Declaración completa: Garantizar que las identidades digitales, firmas electrónicas y transacciones en el ecosistema digital español sean verificables, auténticas e irrefutables.

Base normativa: eIDAS 2 (UE 2024/1183) Arts. 3, 24, 26; ENS Dimensión Autenticidad + Trazabilidad; DORA Art. 9.

Indicadores asignados: I-04 (Firma Digital), AT-01 (Trazabilidad de Sesiones)

Pregunta QQM de nivel superior: ¿En qué medida pueden las organizaciones españolas demostrar de forma irrefutable la identidad de los actores y la integridad de las transacciones digitales?

OBJ-NAC-05: Gobernanza de la Inteligencia Artificial

Declaración completa: Garantizar que el uso de sistemas de inteligencia artificial en organizaciones españolas esté inventariado, evaluado en riesgos y gobernado por políticas formales que prevengan usos inadecuados con datos confidenciales.

Base normativa: EU AI Act (UE 2024/1689) Arts. 9, 28; ISO/IEC 42001:2023; RGPD Art. 25 (privacy by design).

Indicadores asignados: C-06 (Shadow AI), AT-02 (Cultura — vertiente IA)

Pregunta QQM de nivel superior: ¿En qué medida conocen y gobiernan las organizaciones españolas el uso real de herramientas de IA, incluyendo las no autorizadas?

OBJ-NAC-06: Preparación para la Transición Post-Cuántica

Declaración completa: Garantizar que las organizaciones españolas con datos y sistemas de larga vida útil inicien el inventario, evaluación y migración progresiva hacia algoritmos criptográficos resistentes a computación cuántica.

Base normativa: NIST FIPS 203 (ML-KEM), 204 (ML-DSA), 205 (SLH-DSA) — publicados agosto 2024; NSA CNSA 2.0; CCN-STIC-807 (en revisión).

Indicadores asignados: C-04 (Cripto-Agilidad PQC), C-03b (Algoritmos aprobados)

Pregunta GQM de nivel superior: ¿En qué medida están preparadas las organizaciones españolas para migrar su infraestructura criptográfica antes de que los ordenadores cuánticos puedan comprometer los algoritmos actuales?

SECCIÓN 3: TABLA GQM COMPLETA — TRAZABILIDAD

OBJETIVO→PREGUNTA→MÉTRICA

3.1 Pilar Confidencialidad (C)

ID Métrica	Sub-métrica	Objetivo GQM	Pregunta GQM	Fórmula	Unidad	Umbral Crítico	Umbral Objetivo	Frecuencia	Fuente Datos
M-C01a	MFA Coverage Rate	OBJ-NAC-01	¿Qué % de cuentas activas tiene MFA?	$(\text{Cuentas con MFA} / \text{Total cuentas activas}) \times 100$	%	< 70%	≥ 99%	Mensual	IAM/AAD
M-C01b	Phishing-Resistant MFA	OBJ-NAC-01	¿Qué % de MFA usa factores resistentes al phishing?	$(\text{Cuentas FIDO2/cert} / \text{Cuentas con MFA}) \times 100$	%	< 30%	≥ 80%	Mensual	IAM/FIDO2 registry
M-C01c	MFA Bypass Rate	OBJ-NAC-01	¿Cuántos intentos de bypass de MFA se detectan?	Alertas bypass MFA / Total intentos MFA	ratio	> 0,01	= 0	Semana l	SIEM/IdP logs
M-C02a	Orphan Account Rate	OBJ-NAC-01	¿Qué % de cuentas pertenecen a ex-empleados activos?	$(\text{Cuentas activas sin empleado HR} / \text{Total cuentas}) \times 100$	%	> 5%	≤ 1%	Mensual	IAM + HR sync

M-C02b	Access Review Freque ncy	OBJ- NAC-01	¿Con qué frecuen cia se revisan accesos privileg iados?	Revisio nes realiza das / Revisio nes planific adas	ratio 0- 1	< 0,5	= 1,0	Trimest ral	IGA/ PAM logs
M-C02c	PAM Coverag e	OBJ- NAC-01	¿Qué % de cuentas admin están en PAM?	(Cuenta s admin en PAM / Total cuentas admin) × 100	%	< 60%	≥ 95%	Mensu al	PAM platfor m
M-C02d	Least Privileg e Score	OBJ- NAC-01	¿Qué % de usuario s tienen solo los privileg ios necesar ios?	(Usuari os con privileg ios verifica dos / Total usuario s) × 100	%	< 40%	≥ 85%	Trimest ral	IGA tool
M-C03a	Encrypt ion at Rest	OBJ- NAC-01	¿Qué % de repos de datos sensibl es están cifrados ?	(Repos cifrados / Total repos datos sensibl es) × 100	%	< 60%	= 100%	Mensu al	CSPM/ DSPM
M-C03b	Algorit hm Compli ance	OBJ- NAC-01	¿Todos los sistema s usan algorit mos aproba dos?	(Sistem as con algos aproba dos / Total sistema s) × 100	%	< 80%	= 100%	Trimest ral	Scanne r cripto

M-C03c	KMS Separation	OBJ-NAC-01	¿Las claves están separadas de los datos?	Binario : 1 = separación completa	0/1	= 0	= 1	Semestral	Auditoría KMS
M-C04a	Crypto Inventory	OBJ-NAC-06	¿Qué % de sistemas tienen inventario criptográfico?	(Sistemas inventariados / Total sistemas) × 100	%	< 20%	≥ 80%	Semestral	Crypto scanner
M-C04b	Q-Vulnerable Exposure	OBJ-NAC-06	¿Qué % usa RSA/EC C sin plan de migración PQC?	(Sistemas RSA/EC C sin roadmap PQC / Total) × 100	%	> 80%	≤ 20%	Semestral	Crypto inventory
M-C04c	PQC Migration Score	OBJ-NAC-06	¿En qué etapa del roadmap PQC está la organización?	Escala 0-4: 0=sin inventario, 1=inventario, 2=piloto, 3=migración, 4=completado	0-4	≤ 1	≥ 3	Semestral	Crypto roadmap doc
M-C05a	DLP Coverage	OBJ-NAC-01	¿Qué % de canales de salida tiene DLP?	(Canales cubiertos DLP / Total canales identificados) × 100	%	< 50%	≥ 90%	Mensual	DLP platform

M-C05b	DLP Block Rate	OBJ- NAC-01	¿Qué % eventos DLP son bloquea dos (no solo alertad os)?	(Evento s bloquea dos / Total eventos DLP) × 100	%	< 30% (bloque o real)	≥ 70%	Mensu al	DLP reports
M-C05c	DLP False Positive Rate	OBJ- NAC-01	¿Cuál es la tasa de falsos positivo s DLP?	(Alerta s FP / Total alertas DLP) × 100	%	> 50%	≤ 15%	Mensu al	DLP + análisis manual
M-C06a	Shadow AI Rate	OBJ- NAC-05	¿Cuánt as herra mientas IA no autoriz adas se detecta n?	(Herra mienta s AI detecta das no invent ariadas / Total detecta das) × 100	%	> 50%	≤ 10%	Trimest ral	CASB + proxy logs
M-C06b	AI Policy Maturit y	OBJ- NAC-05	¿Existe política formal de IA con nivel de madure z evaluad o?	Escala 0-5: 0=no existe, 1=borra dor, 2=apro bada, 3=com unicada , 4=aplic ada, 5=audit ada	0-5	≤ 1	≥ 3	Semestr al	Doc govern ance

M-C06c	Unauth orized AI Detecti ons	OBJ- NAC-05	¿Cuánt as instanc ias de IA no autoriz ada se detecta n en auditor ía?	Númer o de instanc ias detecta das en auditor ía semestr al	# / período	> 10	= 0	Semestr al	Auditor ía CASB
---------------	--	----------------	---	--	----------------	------	-----	---------------	--------------------

3.2 Pilar Integridad (I)

ID Métrica	Sub- métrica	Objetivo o GQM	Pregunta GQM	Fórmula	Unidad	Umbral Crítico	Umbral Objetivo	Frecuencia	Fuente Datos
M-I01a	FIM Coverage	OBJ- NAC-02	¿Qué % de sistemas críticos tienen FIM activo?	(Sistemas críticos con FIM / Total sistemas críticos) × 100	%	< 60%	≥ 95%	Mensual	FIM platform
M-I01b	FIM Detection Time	OBJ- NAC-02	¿Cuál es el tiempo medio de detección FIM?	Mediana de (timestamp alerta FIM – timestamp modificación)	minutos	> 60 min	≤ 5 min	Por evento	SIEM/ FIM logs
M-I01c	FIM- SIEM Integration	OBJ- NAC-02	¿Están los alertas FIM integrados en SIEM con playbook?	Binario : 1 = integración bidireccional con playbook activo	0/1	= 0	= 1	Mensual	SIEM config audit
M-I02a	TMPVC Críticas	OBJ- NAC-02	¿Días medios CVSS≥9 sin parche?	Mediana de (Fecha parcheo – Fecha publicación CVE) para CVSS≥9	días	> 15 días	≤ 7 días	Semana l	Vuln scanner + CMB

M-I02b	TMPVC Altas	OBJ- NAC-02	¿Días medios CVSS≥7 sin parche?	Median a de (Fecha parche o – Fecha pub CVE) para CVSS 7- 8.9	días	> 30 días	≤ 15 días	Semana 1	Vuln scanner
M-I02c	CVE Age > 30d	OBJ- NAC-02	¿Cuánt os CVE críticos llevan > 30 días sin parche?	Count CVE CVSS≥9 con Age > 30 días	#	> 0 (KPI)	= 0	Semana 1	Vuln scanner
M-I02d	EPSS Patch Rate	OBJ- NAC-02	¿% CVE con EPSS>0, 5 parchea dos en ≤7 días?	(CVE EPSS>0, 5 parchea dos ≤7d / Total CVE EPSS>0, 5) × 100	%	< 60%	≥ 95%	Semana 1	EPSS API + scanner
M-I03a	SBOM Coverag e	OBJ- NAC-02	¿Qué % de aplicaci ones tiene SBOM actualiz ado?	(Apps con SBOM actualiz ado ≤90d / Total apps prod) × 100	%	< 10%	≥ 80%	Trimest ral	CI/CD + SBOM repo
M-I03b	Artifact Verifica tion	OBJ- NAC-02	¿Qué % artefact os SW son verifica dos criptog ráficam ente en CI/CD?	(Artefa ctos verifica dos / Total artefact os despleg ados) × 100	%	< 50%	= 100%	Mensu al	CI/CD pipelin e logs

M-I03c	Third-Party Breach Rate	OBJ-NAC-02	¿Qué % incidentes tienen origen en proveedores?	(Incidentes origen tercero / Total incidentes) × 100	%	> 30%	≤ 10%	Trimestral	Registro incidentes
M-I04a	Signature Coverage	OBJ-NAC-04	¿Qué % transacciones críticas tienen firma cualificada?	(Trans. firmadas cualificadas / Trans. críticas totales) × 100	%	< 60%	= 100%	Mensual	eIDAS/PKI platform
M-I04b	PKI Health Score	OBJ-NAC-04	¿Qué % certificados están válidos y no expirados?	(Certs válidos / Total certs en uso) × 100	%	< 90%	= 100%	Mensual	Certificate mgmt
M-I04c	Expiry Advance Notice	OBJ-NAC-04	¿Días de antelación promedio en renovación de certs?	Promedio de (Fecha renovación - Fecha expiración)	días	< 7 días	≥ 30 días	Mensual	PKI monitoring
M-I05a	Log Centralization	OBJ-NAC-02	¿Qué % sistemas críticos envían logs al SIEM?	(Sistemas con logging centralizado / Total sistemas críticos) × 100	%	< 60%	≥ 95%	Mensual	SIEM inventory

M-I05b	Log Retention	OBJ-NAC-02	¿Qué % sistemas cumplen retención de logs según ENS?	(Sistemas con retención $\geq$ req. normativo / Total) $\times$ 100	%	< 70%	= 100%	Trimestral	SIEM config + policy
M-I05c	Log Integrity and Verification	OBJ-NAC-02	¿Se verifica la integridad de los logs regularmente?	Verificaciones realizadas / Verificaciones programadas	ratio 0-1	< 0,5	= 1,0	Mensual	Verification logs

3.3 Pilar Disponibilidad (A) y Extensiones CIANA

ID Métrica	Sub- métrica	Objetivo GQM	Pregunta GQM	Fórmula	Unidad	Umbral Crítico	Umbral Objetivo	Frecuencia	Fuente Datos
M-A01a	MTTD	OBJ-NAC-03	¿Días medios entre inicio y detección de incidente?	Mediana de (Fecha detección – Fecha inicio estimado)	días	> 90 días	≤ 30 días	Mensual	ITSM/ SOAR + forense
M-A01b	Automated Detection Rate	OBJ-NAC-03	¿Qué % incidentes detecta la tecnología (vs. humano)?	(Incidentes detección automática / Total incidentes) × 100	%	< 30%	≥ 70%	Mensual	SIEM/ SOAR reports
M-A01c	SOC Coverage	OBJ-NAC-03	¿Qué % del tiempo hay analistas SOC activos?	Horas con SOC activo / Total horas (168h/semana)	%	< 50%	= 100% (24×7)	Mensual	SOC scheduling
M-A02a	MTTR	OBJ-NAC-03	¿Horas medias entre detección y resolución?	Mediana de (Fecha resolución – Fecha detección)	horas	> 72h	≤ 4h (P1)	Mensual	ITSM

M-A02b	MTTC	OBJ-NAC-03	¿Horas medias entre detección y contención?	Mediana de (Tiempo de detección – Tiempo de detección)	horas	> 24h	≤ 2h (P1)	Mensual	ITSM/ SOAR
M-A02c	Notification Compliance	OBJ-NAC-03	¿Qué % incidentes notificables se notifican en plazo?	(Notificaciones en plazo / Total notificables) × 100	%	< 80%	= 100%	Por evento	ITSM + registros INCIBE /CCN
M-A02d	IR Playbook Coverage	OBJ-NAC-03	¿Qué % tipologías de incidentes tienen playbook probado?	(Tipologías con playbook probado / Total tipologías) × 100	%	< 40%	≥ 80%	Trimestral	SOAR playbook registry
M-A03a	RTO Definition Coverage	OBJ-NAC-03	¿Qué % sistemas críticos tienen RTO definido en BIA?	(Sistemas con RTO formal / Total sistemas críticos) × 100	%	< 50%	= 100%	Semestral	BIA documents

M-A03b	RTO Test Compliance	OBJ- NAC-03	¿Qué % sistemas alcanzan su RTO en la última prueba ?	(Sistemas RTO alcanzado / Total sistemas probados) × 100	%	< 50%	≥ 90%	Trimestral	DRP test reports
M-A03c	RPO Test Compliance	OBJ- NAC-03	¿Qué % sistemas alcanzan su RPO en la última prueba ?	(Sistemas RPO alcanzado / Total sistemas probados) × 100	%	< 50%	≥ 90%	Trimestral	DRP test reports
M-A03d	BCP Test Frequency	OBJ- NAC-03	¿Cuántos ejercicios BCP/DRP se realizan vs. planificados?	Ejercicios realizados / Ejercicios planificados	ratio 0-1	< 0,5	= 1,0	Anual	BCP exercise records
M-A04a	Availability Rate	OBJ- NAC-03	¿Uptime efectivo de servicios críticos ?	(Tiempo disponible / Tiempo total) × 100	%	< 99%	≥ 99,9%	Continuo	Monitoring platform
M-A04b	Unplanned Downtime	OBJ- NAC-03	¿Horas de inactividad no planificada en 12 meses?	Suma horas inactividad no planificada	horas/año	> 87,6h	≤ 8,76h	Mensual acumulado	Monitoring + ITSM

M-A04c	SLA Compliance	OBJ-NAC-03	¿Qué % períodos se cumple el SLA de disponibilidad?	(Períodos en SLA / Total períodos medidos) × 100	%	< 90%	= 100%	Mensual	SLA reports
M-A05a	Backup Verification	OBJ-NAC-03	¿Qué % backups han sido verificados con restauración?	(Backups verificados / Total backups en 30 días) × 100	%	< 50%	= 100%	Mensual	Backup platform logs
M-A05b	Backup Isolation Score	OBJ-NAC-03	¿Nivel de aislamiento de backups de la red producción?	0=sin aislamiento, 1=VLAN, 2=red separada, 3=air-gap	0-3	≤ 1	≥ 2	Trimestral	Network architecture audit
M-A05c	Ransomware Recovery Test	OBJ-NAC-03	¿% ejercicios ransomware completados vs. planificados?	Ejercicios ransomware realizados / Planificados	ratio 0-1	< 0,5	= 1,0	Semestral	DRP exercise records
M-A05d	Recovery vs. RTO Ratio	OBJ-NAC-03	¿Ratio tiempo real recuperación vs. RTO en simulacro?	Tiempo real recuperación (ejercicio) / RTO definido	ratio	> 2,0	≤ 0,8	Semestral	DRP test reports

M-A06a	Edge Patch Latency	OBJ-NAC-02/03	¿Días entre CVE borde publicado y parche o en prod?	Mediana de (Fecha parche o borde - Fecha pub CVE)	días	> 30 días	≤ 7 días	Semana 1	Patch mgmt + inventory
M-A06b	Edge Inventory Completeness	OBJ-NAC-02/03	¿Qué % dispositivos borde están inventariados?	(Dispositivos borde en inv. / Estimación total) × 100	%	< 80%	≥ 98%	Mensual	Network discovery
M-A06c	KEV Monitoring	OBJ-NAC-02/03	¿Qué % dispositivos borde monitorizan CISA KEV?	(Dispositivos con KEV monitoring / Total borde) × 100	%	< 50%	≥ 95%	Semana 1	Vuln mgmt platform
M-AT01a	Session Recording	OBJ-NAC-04	¿Qué % sesiones privilegiadas son grabadas?	(Sesiones administradas / Total sesiones administradas) × 100	%	< 70%	≥ 98%	Mensual	PAM platform
M-AT01b	Record Integrity	OBJ-NAC-04	¿Son inmutables los registros de sesión?	Binario : 1 = almacenamiento inmutable + acceso separado	0/1	= 0	= 1	Trimestral	PAM + storage audit

M-AT02a	Training Completion	OBJ-NAC transversal	¿Qué % empleados completaron formación anual?	(Empleados con cert. formación / Total plantilla) × 100	%	< 50%	≥ 95%	Anual	LMS platform
M-AT02b	Phishing Click Rate	OBJ-NAC transversal	¿Tasa de clics en simulacros de phishing?	(Clics en phishing simulado / Mensajes enviados) × 100	%	> 20%	≤ 5%	Trimestral	Phishing simulation platform
M-AT02c	Incident Report Rate	OBJ-NAC transversal	¿Qué % incidentes son reportados activamente?	(Reportes voluntarios / Incidentes detectados total) × 100	%	< 20%	≥ 60%	Mensual	ITSM + ticketing
M-AT02d	Executive Training	OBJ-NAC transversal (NIS2)	¿Qué % directivos completaron formación NIS2?	(Directivos formados / Total órgano directivo) × 100	%	< 100%	= 100%	Anual	LMS + directorio directivos

M-AT03a	ZT Maturit y Level	OBJ-NAC-01/03	¿Nivel CISA ZT Maturit y de la organiz ación?	Escala 0-3 CISA ZTA v2: 0=Trad itional, 1=Initia l, 2=Adva nced, 3=Opti mal	0-3	≤ 1	≥ 2	Semestr al	CISA ZT Assess ment
M-AT03b	Microse gment ation	OBJ-NAC-01/03	¿Qué % segmen tos críticos tienen microse gmenta ción?	(Segme ntos con microse g. / Total segmen tos críticos) × 100	%	< 30%	≥ 80%	Trimest ral	Networ k archite cture
M-AT03c	Continu ous Auth Coverag e	OBJ-NAC-01	¿Qué % usuario s en activos críticos tienen autenti cación continu a?	(Usuari os con auth continu a en activos críticos / Total) × 100	%	< 10%	≥ 70%	Trimest ral	ZT platfor m

SECCIÓN 4: ÍNDICE GLOBAL DE MADUREZ CIA (IGM-CIA)

4.1 Fórmula del Índice

El IGM-CIA es un indicador compuesto que agrega los 22 indicadores en un único score de madurez en escala 0-5.

Paso 1: Normalización individual por indicador

Para cada métrica M_i con valor V_i , umbral crítico VC_i y umbral objetivo VO_i :

Score_i = 0 si V_i en zona crítica (peor que umbral crítico)
Score_i = 1 si V_i entre umbral crítico y 50% del rango hacia objetivo
Score_i = 2 si V_i en 50-75% del rango hacia objetivo
Score_i = 3 si V_i en 75-99% del rango hacia objetivo
Score_i = 4 si V_i ≥ umbral objetivo
Score_i = 5 si V_i supera umbral objetivo en ≥ 10%

Paso 2: Score por pilar

IGM_C = (Σ Score_i × Peso_i para indicadores C) / Suma_pesos_C
IGM_I = (Σ Score_i × Peso_i para indicadores I) / Suma_pesos_I
IGM_A = (Σ Score_i × Peso_i para indicadores A) / Suma_pesos_A
IGM_{CIANA} = (Σ Score_i × Peso_i para indicadores CIANA) / Suma_pesos_CIANA

Paso 3: IGM-CIA Global

IGM-CIA = 0,30 × IGM_C + 0,30 × IGM_I + 0,30 × IGM_A + 0,10 × IGM_{CIANA}

Pesos sectoriales recomendados (ajustar según sector y criticidad):

Sector	w _C	w _I	w _A	w _{CIANA}
Financiero (DORA)	0,25	0,25	0,40	0,10
Salud	0,40	0,25	0,25	0,10
Infraestructura crítica	0,20	0,25	0,45	0,10
AAPP	0,30	0,30	0,30	0,10
PYMEs (genérico)	0,35	0,25	0,30	0,10
Defensa / Seguridad Nacional	0,30	0,30	0,20	0,20

4.2 Escala de Interpretación del IGM-CIA

Puntuación IGM-CIA	Nivel de Madurez	Descripción	Acción
0,0 - 1,0	Inicial	Controles básicos ausentes; exposición crítica	Plan de emergencia 30 días
1,0 - 2,0	Formativo	Controles puntuales sin coherencia sistémica	Programa estructurado 90 días
2,0 - 3,0	Definido	Controles implementados; cobertura parcial	Plan de mejora continua 6 meses
3,0 - 4,0	Gestionado	Controles completos con medición sistemática	Optimización y automatización
4,0 - 5,0	Optimizado	Programa maduro con mejora continua documentada	Benchmark sectorial y liderazgo

4.3 Correlación PRAGMATIC con IGM-CIA

Los indicadores con score PRAGMATIC Clase A tienen peso $\times 1,2$ en el IGM-CIA. Los de Clase C tienen peso $\times 0,8$. Esto refleja que las métricas de mayor calidad metodológica merecen mayor influencia en el índice agregado.

SECCIÓN 5: PESOS PRAGMATIC EN EL CONTEXTO ESPAÑOL

5.1 Ajuste de Pesos por Contexto Nacional

España 2025 presenta tres condiciones contextuales que justifican pesos diferenciados en los criterios PRAGMATIC:

Peso +1 en Relevante para indicadores con base en NIS2 y DORA: La transposición de NIS2 en tramitación y DORA en vigor desde enero 2025 elevan la relevancia regulatoria de los indicadores vinculados a estos marcos por encima de la media internacional.

Peso +1 en Rentable para indicadores aplicables a PYMEs: El 99,8% del tejido empresarial español son PYMEs. Los indicadores cuya extracción requiere herramientas de alto coste (CSPM, IGA enterprise) tienen impacto limitado sobre la mayoría del tejido productivo y deben ser ponderados de forma realista.

Peso +1 en Predictivo para indicadores de Disponibilidad en sectores críticos: El impacto de los 392 ataques de ransomware en 2025 en España hace que la capacidad predictiva de los indicadores de disponibilidad sea especialmente valiosa en el contexto nacional.

SECCIÓN 6: RUTA DE IMPLEMENTACIÓN RECOMENDADA

Fase 0 — Prerequisitos (semanas 1-2)

- Inventario de activos actualizado (condición sine qua non de precisión)
- Definición del alcance organizacional (sistemas dentro/fuera de métricas)
- Asignación de propietarios de métricas por dominio

Fase 1 — Quick Wins (meses 1-3): Indicadores Clase A sin inversión adicional

- TMPVC (M-I02a-d): extracción del vulnerability scanner existente
- MFA Coverage (M-C01a): extracción del IAM/AAD existente
- Uptime (M-A04a-c): extracción del sistema de monitorización existente
- MTTD/MTTR (M-A01a, M-A02a): extracción del ITSM existente

Fase 2 — Consolidación (meses 3-9): Indicadores con herramientas existentes

- FIM (M-I01a-c): despliegue de agentes FIM si no existen
- Log Centralization (M-I05a-c): revisión y ampliación de cobertura SIEM
- Backup Verification (M-A05a): activación de proceso mensual de restauración de test
- Training Metrics (M-AT02a-d): extracción de LMS y plataforma phishing simulation

Fase 3 — Inversión dirigida (meses 9-18): Indicadores que requieren nuevas herramientas

- DLP Coverage (M-C05a-c): evaluación e implementación/ampliación de plataforma DLP
- Encryption at Rest (M-C03a-c): implementación CSPM/DSPM
- Supply Chain / SBOM (M-I03a-c): integración SBOM en pipeline CI/CD
- ZT Microsegmentation (M-AT03b): proyecto de microsegmentación de red

Fase 4 — Liderazgo estratégico (> 18 meses): Indicadores de madurez avanzada

- PQC Inventory (M-C04a-c): implementación de herramienta de escaneo criptográfico
- Shadow AI Governance (M-C06a-c): política IA + CASB con capacidades específicas
- Zero Trust Maturity (M-AT03a-c): evaluación formal CISA ZT Maturity

Marco Integrativo GQM+PRAGMATIC CIA Triad v2025 · Basado en: Basili & Weiss (1984) GQM; ISO/IEC 15939 Software Measurement; Brotby & Hinson PRAGMATIC (2013); NIST SP 800-55 R1; ENS RD 311/2022; NIS2 (UE 2022/2555); DORA (UE 2022/2554); RGPD (UE 2016/679); EU AI Act (UE 2024/1689); eIDAS 2 (UE 2024/1183); NIST CSF 2.0; NIST PQC FIPS 203/204/205; CISA ZTA Maturity Model v2; IBM Cost of Data Breach 2025; Verizon DBIR 2025; ENISA Threat Landscape 2025; Cisco CRI 2025